ZAP by Checkmarx Scanning Report

Generated with ZAP on Mon 20 Apr 2026, at 15:32:31

ZAP Version: 2.17.0

ZAP by Checkmarx

Contents

- About This Report
  - Report Parameters
- Summaries
  - Alert Counts by Risk and Confidence
  - Alert Counts by Site and Risk
  - Alert Counts by Alert Type
  - Insights
- Alerts
  - Risk=High, Confidence=Medium (1)
  - Risk=Medium, Confidence=High (2)
  - Risk=Medium, Confidence=Medium (1)

- Risk=Medium, Confidence=Low (1)
- Risk=Low, Confidence=High (1)
- Risk=Low, Confidence=Medium (3)
- Risk=Informational, Confidence=Medium (4)

- Appendix
  - Alert Types

About This Report

Report Parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- `http://demo.testfire.net`

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: `High`, `Medium`, `Low`, `Informational`

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert Counts by Risk and Confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
		User Confirmed	High	Medium	Low	Total
Risk	High	0 (0.0%)	0 (0.0%)	1 (7.7%)	0 (0.0%)	1 (7.7%)
	Medium	0 (0.0%)	2 (15.4%)	1 (7.7%)	1 (7.7%)	4 (30.8%)
	Low	0 (0.0%)	1 (7.7%)	3 (23.1%)	0 (0.0%)	4 (30.8%)
	Informational	0 (0.0%)	0 (0.0%)	4 (30.8%)	0 (0.0%)	4 (30.8%)
	Total	0 (0.0%)	3 (23.1%)	9 (69.2%)	1 (7.7%)	13 (100%)

Alert Counts by Site and Risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

		Risk			
		High (= High)	Medium (>= Medium)	Low (>= Low)	Informational (>= Informational)
Site	http://demo.testfire.net	1 (1)	4 (5)	4 (9)	4 (13)

Alert Counts by Alert Type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
SQL Injection - SQLite (Time Based)	High	1 (7.7%)
Absence of Anti-CSRF Tokens	Medium	3 (23.1%)
Total		13

Alert type	Risk	Count
Content Security Policy (CSP) Header Not Set	Medium	5 (38.5%)
Missing Anti-clickjacking Header	Medium	5 (38.5%)
Sub Resource Integrity Attribute Missing	Medium	1 (7.7%)
Cookie without SameSite Attribute	Low	3 (23.1%)
Cross-Domain JavaScript Source File Inclusion	Low	1 (7.7%)
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	5 (38.5%)
X-Content-Type-Options Header Missing	Low	5 (38.5%)
Information Disclosure - Suspicious Comments	Informational	5 (38.5%)
Modern Web Application	Informational	4 (30.8%)
Session Management Response Identified	Informational	3 (23.1%)
User Agent Fuzzer	Informational	5 (38.5%)
Total		13

Insights

This table shows information that is likely to be very relevant to you, but which is not related to vulnerabilities, or potentially even related to the application in question.

Level	Reason	Site	Description	Statistic
Medium	Exceeded Low		Percentage of memory used	80
Low	Warning		ZAP warnings logged - see the zap.log file for details	25
Low	Exceeded Low		Percentage of network failures	11 %
Low	Exceeded High	http://demo.testfire.net	Percentage of slow responses	100 %
Info	Informational	http://demo.testfire.net	Percentage of responses with status code 2xx	50 %
Info	Informational	http://demo.testfire.net	Percentage of responses with status code 3xx	13 %
Info	Exceeded Low	http://demo.testfire.net	Percentage of responses with status code 4xx	35 %
Info	Informational	http://demo.t	Percentage of endpoints with	2 %

Level	Reason	Site	Description	Statistic
		estfire.net	content type application/javascript	
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type application/pdf	1 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type application/x-shockwave-flash	1 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type image/gif	8 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type image/jpeg	28 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type image/png	2 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type text/css	2 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with content type text/html	49 %

Level	Reason	Site	Description	Statistic
Info	Informational	http://demo.testfire.net	Percentage of endpoints with method GET	96 %
Info	Informational	http://demo.testfire.net	Percentage of endpoints with method POST	3 %
Info	Informational	http://demo.testfire.net	Count of total endpoints	83
Info	Informational	https://demo.testfire.net	Percentage of responses with status code 2xx	50 %
Info	Informational	https://demo.testfire.net	Percentage of responses with status code 3xx	50 %
Info	Informational	https://demo.testfire.net	Percentage of slow responses	100 %

Alerts

Risk=High, Confidence=Medium (1)

http://demo.testfire.net (1)

SQL Injection - SQLite (Time Based) (1)

▶ GET http://demo.testfire.net/index.jsp?content=inside_jobs.htm&job=Teller:ConsumaerBanking

Risk=Medium, Confidence=High (2)

http://demo.testfire.net (2)

Content Security Policy (CSP) Header Not Set (1)

▶ GET http://demo.testfire.net/robots.txt

Sub Resource Integrity Attribute Missing (1)

▶ GET http://demo.testfire.net/index.jsp?content=personal_investments.htm

Risk=Medium, Confidence=Medium (1)

http://demo.testfire.net (1)

Missing Anti-clickjacking Header (1)

▶ GET http://demo.testfire.net

Risk=Medium, Confidence=Low (1)

http://demo.testfire.net (1)

Absence of Anti-CSRF Tokens (1)

▶ GET http://demo.testfire.net/login.jsp

Risk=Low, Confidence=High (1)

http://demo.testfire.net (1)

Server Leaks Version Information via "Server" HTTP Response Header Field (1)

▶ GET http://demo.testfire.net/robots.txt

Risk=Low, Confidence=Medium (3)

http://demo.testfire.net (3)

Cookie without SameSite Attribute (1)

▶ GET http://demo.testfire.net/robots.txt

Cross-Domain JavaScript Source File Inclusion (1)

▶ GET http://demo.testfire.net/index.jsp?content=personal_investments.htm

X-Content-Type-Options Header Missing (1)

▶ GET http://demo.testfire.net

Risk=Informational, Confidence=Medium (4)

http://demo.testfire.net (4)

Information Disclosure - Suspicious Comments (1)

▶ GET http://demo.testfire.net/login.jsp

Modern Web Application (1)

▶ GET http://demo.testfire.net/index.jsp?content=inside.htm

Session Management Response Identified (1)

▶ GET http://demo.testfire.net

User Agent Fuzzer (1)

▶ POST http://demo.testfire.net/doSubscribe

Appendix

Alert Types

This section contains additional information on the types of alerts in the report.

SQL Injection - SQLite (Time Based)

Source	raised by an active scanner (SQL Injection - SQLite (Time Based))
CWE ID	89
WASC ID	19
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/SQL_Injection_Prevention_Cheat_Sheet.html

Absence of Anti-CSRF Tokens

Source	raised by a passive scanner (Absence of Anti-CSRF Tokens)
CWE ID	352
WASC ID	9
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/Cross-Site_Request_Forgery_Prevention_Cheat_Sheet.html ▪ https://cwe.mitre.org/data/definitions/352.html

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp

- https://caniuse.com/#feat=contentsecuritypolicy
- https://content-security-policy.com/

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	• https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options

Sub Resource Integrity Attribute Missing

Source	raised by a passive scanner (Sub Resource Integrity Attribute Missing)
CWE ID	345
WASC ID	15
Reference	• https://developer.mozilla.org/en-US/docs/Web/Security/Subresource_Integrity

Cookie without SameSite Attribute

Source	raised by a passive scanner (Cookie without SameSite Attribute)
CWE ID	1275

WASC ID	13
Reference	▪ https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site

Cross-Domain JavaScript Source File Inclusion

Source	raised by a passive scanner (Cross-Domain JavaScript Source File Inclusion)
CWE ID	829
WASC ID	15

Server Leaks Version Information via "Server" HTTP Response Header Field

Source	raised by a passive scanner (HTTP Server Response Header)
CWE ID	497
WASC ID	13
Reference	▪ https://httpd.apache.org/docs/current/mod/core.html#servertokens ▪ https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) ▪ https://www.troyhunt.com/shhh-dont-let-your-response-headers/

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	▪ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ▪ https://owasp.org/www-community/Security_Headers

Information Disclosure - Suspicious Comments

Source	raised by a passive scanner (Information Disclosure - Suspicious Comments)
CWE ID	615
WASC ID	13

Modern Web Application

Source	raised by a passive scanner (Modern Web Application)

Session Management Response Identified

Source	raised by a passive scanner (Session Management Response Identified)
Reference	▪ https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/

User Agent Fuzzer

Source	raised by an active scanner (User Agent Fuzzer)
Reference	▪ https://owasp.org/wstg